ASEC

APT

Threat Trend Report on APT Groups – July 2024 Major Issues on APT Groups

Aug 12 2024

Purpose and Scope

This report covers nation-led threat groups presumed to conduct cyber espionage or sabotage under the support of the governments of certain countries, referred to as "Advanced Persistent Threat (APT) groups" for the sake of convenience. Therefore, this report does not contain information on cybercriminal groups aiming to gain financial profits.

We organized analyses related to APT groups disclosed by security companies and institutions including AhnLab during the previous month; however, the content of some APT groups may not have been included.

The names and classification criteria may vary depending on the security company or researcher, and in this report, we used well-known names of AhnLab Threat Intelligence Platform (ATIP)'s threat actors.

APT Group Trends

The cases of major APT groups for July 2024 gathered from materials made public by security companies and institutions are as follows.

1) APT17

TG SOFT revealed the activities of the APT17 group, which targeted Italian companies and government agencies in June and July 2024.[1]

In the first attack, the threat actors sent a malicious MS Office document, and in the second attack, they sent an email containing a malicious link. Both attacks coerced victims into installing a Skype for Business package containing the 9002Rat malware.

The 9002Rat malware, which features proxy functions for monitoring network traffic, is modular malware capable of downloading plugins to extend its functionality. Although it is an older malware, it continues to be updated in 2024.

The use of a government agency link on the malicious page suggests that the threat actors utilized confidential information from previously infected Italian companies or institutions.

2) APT40

CISA[2] and BitDefender[3] reported that the APT40 group targeted Australian networks in a series of attacks.

APT40 attempted multiple intrusions into Australian networks by exploiting publicly known vulnerabilities in widely used software, including Log4J, Atlassian Confluence, and Microsoft Exchange.

During the initial intrusion phase, they used web shells to maintain persistence and leveraged small office/home office (SOHO) devices as infrastructure, making detection more difficult.

In another instance of attack, APT40 attacked networks through remote access portals, collecting hundreds of valid usernames and passwords.

3) APT41

Zscaler ThreatLabz has disclosed information about a new loader, DodgeBox,[4] and a new backdoor, MoonWalk,[5] used by APT41.

DodgeBox is similar to a variant of StealthVector and employs various evasion techniques. Notably, it uses Google Drive for C2 communication. This loader avoids detection through techniques such as environment checks, DLL side-loading, and DLL hollowing, and encrypts its configuration using AES-CFB mode.

MoonWalk is loaded via DodgeBox and also uses Google Drive for C2 communication. It employs techniques such as DLL hollowing, import resolution, DLL unhooking, and stack spoofing. Additionally, it attempts to bypass security programs using Windows Fibers. MoonWalk's modular design allows it to be easily updated and modified to suit various scenarios.

Mandiant reported that APT41 targeted the shipping and logistics sectors in Europe and the Middle East, as well as the media and entertainment sectors in Asia.[6] APT41's key malware strains, DUSTPAN and DUSTTRAP, function through an in-memory dropper and a multi-stage plugin framework, respectively. SQLULDR2 and PINEGROVE were respectively used as data extraction and upload tools. To sign their malware, this group used code-signing certificates, which were found to be stolen from companies in the gaming industry. APT41 maintained persistence on Tomcat Apache Manager servers using the ANTSWORD and BLUEBEAM web shells. These web shells have been active since 2023, executing certutil.exe to download the DUSTPAN dropper, which then loads BEACON. DUSTTRAP minimizes traces by executing the malicious payload directly from the memory.

4) Andariel (APT45)

The US government has indicted[7] individuals associated with the Andariel group and issued warnings about the group's activities.[8] Microsoft[9] and Mandiant[10] have also released information regarding Andariel's operations.

This group began its intensive activities targeting government agencies and the defense industry in 2017, and in 2019, activities were detected in conjunction with its continued focus on nuclear issues and energy.

The Andariel group primarily targets sensitive military information and intellectual property in the defense, aerospace, nuclear, and engineering sectors, and has also attacked the medical and energy industries to some extent. They primarily conduct ransomware attacks on US medical institutions to fund their espionage activities, and in some cases, they carry out ransomware attacks and cyber espionage activities simultaneously on the same day.

The group exploits vulnerabilities such as Apache ActiveMQ (CVE-2023-46604), TeamCity (CVE-2023-42793), and Citrix NetScaler (CVE-2023-3519).

Their primary malware includes Atharvan, ELF Backdoor, Jupiter, MagicRAT, TigerRAT, SmallTiger, LightHand, and ValidAlpha, while they obfuscated the malware using commercial tools such as Sliver, Themida, and VMProtect.

[1] https://www.tgsoft.it/news/news_archivio.asp?id=1557

[2] https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-190a

[3] https://www.bitdefender.com/blog/businessinsights/understanding-apt40-insights-from-cisas-latest-joint-security-advisory/

[4] https://www.zscaler.com/blogs/security-research/dodgebox-deep-dive-updated-arsenal-apt41-part-1

[5] https://www.zscaler.com/blogs/security-research/moonwalk-deep-dive-updated-arsenal-apt41-part-2

[6] https://cloud.google.com/blog/topics/threat-intelligence/apt41-arisen-from-dust/

[7] https://www.fbi.gov/wanted/cyber/rim-jong-hyok

[8] https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-207a

[9] https://www.microsoft.com/en-us/security/blog/2024/07/25/onyx-sleet-uses-array-of-malware-to-gather-intelligence-for-north-korea/

[10] https://cloud.google.com/blog/topics/threat-intelligence/apt45-north-korea-digital-military-machine/

Tags: 2024년7월APT그룹동향 Andariel APT17 APT40 APT41 APT45 APT그룹동향 CloudSorcerer EvasivePanda GuardZoo Kimsuky Lazarus MirrorFace MuddyWater MustangPanda OceanLotus OilAlpha Patchwork SideWinder TAG-100 TransparentTribe Turla

Previous Post

Threat Trend Report on APT Attacks – July 2024 Major Issues on APT Attacks in South Korea

Next Post

Distribution of MSC File Exploiting Amazon Service